# Monthly Intelligence Dispatch

January 2017

The Group-IB monthly threat intelligence dispatch is an overview of the strategic changes to the cyber threat landscape, including the most important incidents, leaks and tactical changes in criminal activity.

This report includes short term forecasts and warnings, which allow you to take timely measures to protect your critical infrastructure, networks and clients. This report comes in addition to the quarterly and yearly reports that Group-IB prepares, provided alongside our operational and technical data in the Intelligence system and RFI requests from our clients completed by our analyst team.

# Executive Summary

- Targeted attacks remain one of the largest threats to financial institutions. The main goal of hackers in recent incidents has been to target critical infrastructure: gain access to interbank transfer systems, ATM networks, payment gateways and card processing infrastructure.
- The geography of banks targeted by APT threats is increasing. Attacks have been identified in countries that were not previously of interest to hackers, including: Tunisia, Brazil, Kazakhstan, Bulgaria, Azerbaijan and Georgia.
- On underground hacking forums, new exploits are on offer alongside the continued sale of tools for targeted attacks. The attack tools released in the Shadow Brokers leak, reportedly developed by the NSA, are now openly accessible.
- Since December new malware for attacking users have appeared for sale, these programs can be used for targeted attacks. For example, Snatch and HVNC33 Trojans for Windows. A new Trojan, build on Zeus source code, has been used to conduct attacks on Canadian banks.
- A new spyware Trojan for MacOS, Proton, has appeared in the wild and gives the attacker a range of methods for remote access to PCs running MacOS.
- Threats to Android mobile devices are continuing to develop aggressively. One Russian-speaking criminal group, previously monickered Honli known before to target only Russian users, has adapted their malware and is now using it to attack eight banks in Australia.
- Phishing attacks on customers of banks, payment systems and hotels have continued. There has been a growth in usage of brute force programs to compromise logins and passwords for banking systems, this is performed using information taken from recent major database leaks.
- In Russia the Cron criminal group was arrested, while in custody they were found to be preparing Android Trojan attacks on French banks
- In the US the suspected creator of the Mirai botnet was identified. This botnet was responsible for conducting the most powerful DDoS attacks in recent years.
- In Spain, the suspected author of the Vawtrak (Neverquest) banking Trojan was arrested. However, attacks using this Trojan have continued.

# Major events

The start of 2017 was dominated by discussion from experts and the mass media on whether "Russian hackers" could have brought Donald Trump to power. Although, no convincing technical evidence was provided that Moscow was responsible for interference in the US electoral processes, the concept of "Russian threats" merits discussion.

Currently, the largest cyber threats are from Russian-speaking actors. But, as identified in our research and incident response, this contingent of hackers are driven primarily by financial gain (not-geopolitics), and their main target remains the financial sector. The most significant threats for banks are targeted attacks, during which, attackers again access to interbank transfer systems, ATM networks and card processing platforms.

One of the more notable developments in targeted attacks, is the increased attention towards banks in emerging markets. Group-IB identified attacks in Brazil, Tunisia and Moldavia. In a recent example, Cobalt group, specializing in logical attacks on ATMs, adapted their methods to attack the WAY4 payment system (One Way Group) at a Kazakh bank. This system is currently used at around 130 banks and represents another potential vector for thefts.

10 minutes — the minimum time in which attackers were able to take control over a bank's network.

Cobalt is one of the most active criminal groups that Group-IB tracks, and we have identified their activity in 14 countries. During incident response, we confirmed that these criminals were responsible for the theft of $2.2 million USD in July 2016 from First Bank ATMs in Taiwan. "ATMSpitter" malware was used in this attack and then again in September 2016 in attacks on European banks. Group-IB forecast that logical attacks on ATMs will become one of the primary vectors to conduct thefts from financial institutions.

There is an additional significant risk for financial institutions, and in particular for SWIFT systems. In Russia at the end of 2016, a newly active criminal group used Moneytaker v.5.0 malware to conduct automated attacks at banks via the ARM CBR (Automated Work Station Client of the Russian Central Bank) payment system and to steal money from accounts of one of Russia's largest banks. In these attacks a range of remote access tools were used alongside utilities for data collection and keylogging.

There is a significant risk that the tools and tactics used to commit automated thefts from ARM CBR could be adapted to the SWIFT system and then used in attacks worldwide.

Cyber criminals are re-investing the funds stolen from the financial sector in new tools for targeted attacks. This is not difficult as there is a steady stream of malware and exploits for sale on underground hacking forums. After testing these newly acquired tools in Russian speaking countries, they are then used to attack banks internationally.

# New Malware & Tools

In January 2017 on Russian speaking hacking forums posts were made declaring the following 0day exploits for sale: for RCE MSWORD, Ubuntu 16-14 LPE and RedHat-CentOS LPE for versions CentOS 7.3/7.2 (64bit), Red Hat Enterprise Linux Server 7.3/7.2 (64bit), Red Hat Enterprise Linux Desktop 7.3/7.2 (64bit), Red Hat Enterprise Linux Workstation 7.3/7.2 (64bit).

At approximately the same time, a collection of the Equation Group tools were made openly available. Despite the fact that a large part of the release is now out of date, with a small amount of modernization these tools can be integrated into banking Trojans or spyware. This is not the first such leak. In this instance the Equation Group server was compromised by the "Shadow Brokers". Judging from the materials published, Equation Group is linked with the development of Stuxnet, Dugu and Flame programs, used in targeted attacks in Iran, Russia, Afghanistan, Pakistan, India and China. For example, in 2008 Equation Group used four zero days, two of which were later used in the Stuxnet worm.

Aside from the Equation Group leak, sales of new exploits, for use in targeted attacks, have intensified on underground hacking forums. Snatch Trojan is on sale, this malware allows threat actors to steal logins and passwords from popular browsers (Google Chrome, Mozilla Firefox, Opera, etc) email and FTP clients. It additionally allows automated upload and launch of files, and anti-virus avoidance.

Another Trojan, Hidden VNC 33, is now being used for hidden remote access to computers running Windows, accordingly it can be employed for targeted attacks on banks or corporate espionage. One peculiarity of the Trojan is its capacity to entirely copy browser profiles (Chrome, Mozilla, Internet Explorer), without the victim's knowledge.

A standard mod built on the Zeus source code was identified, named zbot.ACB. The recently formed Bridebiz criminal group planned attacks on around 30 banks in Canada. Activity from this group may lead to thefts from other financial institutions in other countries.

Malware for Apple operating systems is continuing to be developed. In January, a new spyware program for remote access to MacOS computers (PROTON) was released for sale. This Trojan allows access to all personal user data, password changes, screenshots, capacity to turn off and restart the computer as well as cursor and keystroke control. As company top management often use Apple devices, it is likely that PROTON will be used for industrial espionage, CEO fraud or preparation for targeted attacks.

On another underground forum, source code was released for an android bot (published by user Maza-in) with functionality to receive admin rights, conduct SMS interception and perform web-injects. This malware received significant attention from the criminal underground, sales of this Trojan for private usage had already begun on other resources. There is a significant risk that this bot will be modified for added functionality and used for largescale thefts via mobile banking applications.

At the start of the year a post detailed the sale of a new loader, imaginatively named – Private Android Loader. This was listed at a cost of $1500, and it is used for loading malware to Android phones. Mobile Trojans designed for theft from individuals have almost completely crowded out similar malware for personal computers.

# Current developments

After one of the authors of a banking Trojan provided open access to the source code and control panel, one criminal group, previously only active in the Russian Federation, recalibrated their malware for attacks on banks abroad. The criminal group in question, Honli, uses an adapted Trojan for attacks, now targeting eight Australian banks. Honli has been active since 2015, specializing in injecting android devices with their Trojan to steal bank card and authentication data from victims. Previously they were operational only in Russia. At the end of 2016, the criminal group acquired a new server, on which they uploaded twelve fake web pages, including National Australia bank, St George bank, Westpac, West bank, ME bank amongst others.

Phishing remains one of the main methods to gain access to user credentials, receive bank card data and to gain initial access to networks during targeted attacks. The majority of phishing attacks in January took place in Tuesdays, whereas in December, the most active day was Thursday.

In the reporting period, efforts to use brute force tools on internet banking and other personal accounts became more frequent. The source of data for attempts in recent attacks have been old logins/user names and passwords available after major client database leaks such as LinkedIn and Yahoo.

At the end of 2016, law enforcement agencies dealt several noticeable blows to the criminal underground. In Russia members of the Cron criminal group were arrested. On capture they were found to be preparing attacks on French banks using Android malware. In less than one year they were able to infect more than 1 million mobile devices. Each day, their malware attempted to steal money from around 50 – 60 clients at a range of banks. Their next steps were to rent the Catelites Android Bot v 7.0, a more universal Trojan, and then adapted it for attacks on Banks in the UK, Germany, France, USA, Turkey, Singapore, Australia and other countries. The first targets that the Cron group chose were French banks, but their plans were interrupted by their arrest.

Interpol announced the arrests of five individuals involved with the Cobalt attacks. In this instance, the men held were "mules", low level criminals who collect money from ATMs during logical attacks. They then provide this money for laundering to the attack organizers. Often mules visit countries on tourist visas with the goal of thefts, and leave as soon as the operation is complete. In this case they were slow and a few days after the thefts from First Bank ATMs, local police held three of the criminals. However, thirteen more suspects were able to leave Taiwan. One of the mules was later arrested by Police in Romania, and another by the Investigative Committee of Belarus. These arrests damaged only the lowest level of the Cobalt organizational hierarchy, therefore, the threat from this group is still high.

In the USA, the suspected creator of the Mirai bot net was identified, responsible for one of the most powerful recent DDoS attacks. These included attacks on the website of journalist Brian Krebs, US based Dyn DNS and Deutsche Telekom. The botnet, which leverages IoT device insecurities, was reportedly developed by Christopher "CJ" Sculti, Jr and Paras Jha, who had run DDoS protection services in the past. A full investigation of the Mirai botnet and its origins is available on Krebs' website.

In Spain, a 32-year-old Russian computer programmer, Stanislav Lisov, was arrested. He stands accused of creating the Vawtrak (Neverquest) banking Trojan – one of the most successful Trojans in recent years. Analysis of a server under Lisov's control revealed files with user credentials for several million bank clients. Despite Lisov's arrest, attacks using Vawtrak still continue and this Trojan is set to remain a threat.

# Forecasts and warnings

- The recent successful attack on more than one Russian bank shows that cyber-criminals have access to tools for automatic replacement of payments in interbank transfer systems. With certain adaptations this tool could be used for attacks on SWIFT worldwide.
- After the successful attacks by Cobalt group on the WAY4 payment system (OpenWay Group), around 130 banks are now potential targets.
- During targeted attacks on banks, vulnerabilities in office and server software will be exploited, as these are now being spread on underground hacking forums. Tools included in the Equation Group / Shadow Brokers leak will be researched in details and some of their functions adapted for use in new attacks.
- The PROTON spyware for MacOS may be actively used in targeted attacks such as industrial espionage, CEO fraud or direct theft from bank accounts.
- As a result of the release of the source code for an Android banking Trojan by a threat actor monickered Maza-in, in future clones may appear calibrated for attacks on bank clients worldwide. This will lead to a significantly larger amount of losses, other groups who have used Android Trojans in the past are continuing their activity, and as a minimum one Russian group has already switched their attention from Russian to International banks.
- Logical attacks on ATMs will become one of the primary attack vectors on financial institutions. Additionally, thefts will be from countries that previously were not of interest to cyber criminals in areas such as South-America, South-East Asia, the former Soviet Union and Africa.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com